

# SOCIAL ENGINEER TOOLKIT

## SET

**Integrantes:**

Aguilar Carrizales Miguel Ángel – 182318  
Aznar Cuevas Luis Eduardo – 179880  
Beltrán Reyna David – 183636  
Gómez Arreguín Donaldo Demián – 179822  
Morales Hernández Roberto Emiliano – 182377  
Rosales Ramírez Josué Emiliano – 181760

**Materia:**

CNO V Seguridad Informática

**Profesor:**

López, Servando

**Grupo:**

T46A

## **Contenido**

|                                         |           |
|-----------------------------------------|-----------|
| <b>1. Executive Summary</b>             | <b>2</b>  |
| <b>2. Objetivos</b>                     | <b>2</b>  |
| <b>3. Infraestructura Técnica</b>       | <b>2</b>  |
| <b>4. Metodología y aplicación</b>      | <b>3</b>  |
| <b>5. Resultados</b>                    | <b>9</b>  |
| <b>6. Análisis de riesgos</b>           | <b>9</b>  |
| <b>7. Recomendaciones de mitigación</b> | <b>10</b> |
| <b>8. Bibliografía</b>                  | <b>10</b> |

## Executive Summary

Este documento detalla la ejecución de una simulación de ataque de ingeniería social realizada en un entorno controlado. El objetivo principal fue evaluar la efectividad de las defensas perimetrales contra el correo no deseado y la capacidad de respuesta del usuario ante técnicas de suplantación de identidad (Phishing). Se logró la infiltración exitosa mediante el uso de un servidor SMTP configurado localmente y el despliegue de una página de captura de credenciales adecuadas en el código web y una estricta aplicación del principio de mínimo privilegio.

## Objetivos

### ❖ Objetivo General:

Evaluar la resiliencia de la infraestructura de correo electrónico institucional y la concienciación de los usuarios mediante una simulación de ataque de ingeniería social (Spear Phishing) en un entorno controlado.

### Objetivos Específicos:

- **Despliegue de MTA:** Configurar un Agente de Transferencia de Correo (MTA) basado en Postfix para la manipulación y retransmisión de paquetes SMTP.
- **Auditoría de Vectores de Ataque:** Ejecutar una campaña de *Mass Mailer* mediante Social-Engineer Toolkit (SET) para probar la efectividad de los señuelos basados en HTML.

## Infraestructura Técnica

Para la ejecución del ataque se desplegaron los siguientes componentes:

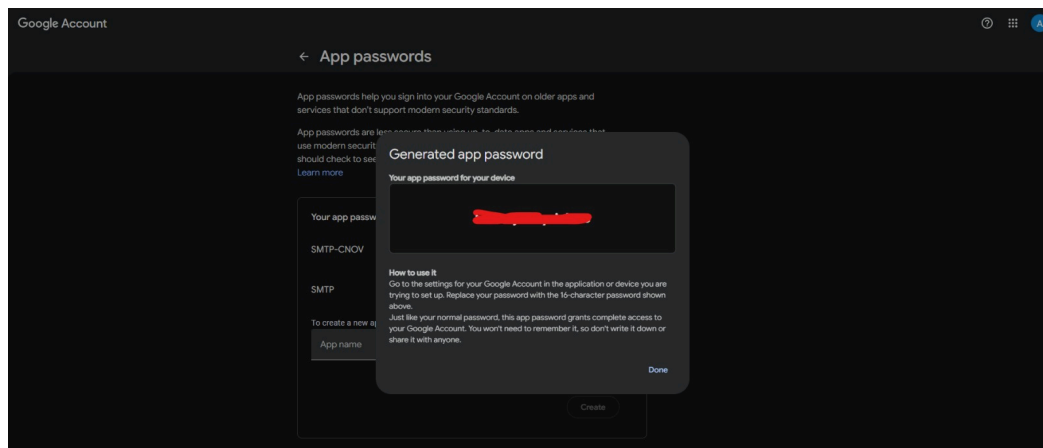
| Componente                  | Descripción                                                                                                     |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------|
| Servidor de Correo (MTA)    | Postfix instalado en Linux.                                                                                     |
| Configuración de Relay      | Uso de <code>sasl_passwd</code> y configuración de SMTP de terceros para garantizar la entrega de los mensajes. |
| Herramienta de Explotación  | Social Engineer Toolkit (SET) - Módulo de Ingeniería Social.                                                    |
| Middleware de Autenticación | <code>libsasl2-modules</code> y <code>sasl2-bin</code> para la gestión de túneles seguros con Google SMTP.      |
| Protocolos                  | MTP (puerto 25) para inyección interna y SMTPS/Submission (puerto 587) para salida cifrada vía TLS.             |

# Metodología y Ejecución

## 1. Preparación de la cuenta de salida (Google App Password)

Para permitir que el servidor Postfix enviara correos a través de una cuenta de Gmail de forma segura, se generó una **App Password** específica. Este paso es crítico para evitar el bloqueo por parte de las políticas de seguridad modernas de Google que no permiten el acceso directo con la contraseña principal.

Para ejecutar este paso exitosamente, es necesario tener la autenticación de dos pasos en el correo a usar.

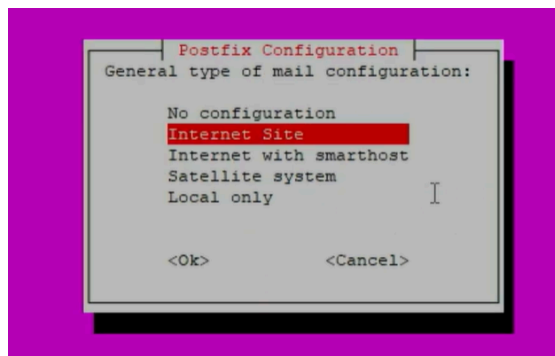


## 1.2 Instalación de postfix y mailutils

Postfix es un servidor de correo que se encarga de enviar y recibir emails, mientras que Mailutils es un conjunto de herramientas que permite gestionar, leer y probar correos desde la terminal. En conjunto, Postfix maneja el transporte del correo y Mailutils te da utilidades para interactuar con él. Herramientas altamente indispensables para la realización de esta práctica. Que se podrá realizar la correcta instalación usando el siguiente comando:

```
(root@kali)-[~]  
# sudo apt-get install postfix mailutils -y
```

Después de empezado la instalación, seremos dirigidos a esta pantalla:



Aquí seleccionamos la opción que está por determinado **Internet Site**.

Se continúa ingresando el nombre del mail del sistema (es arbitrario, el nombre en si no es indispensable para esta práctica)

## 2. Configuración del Servidor Postfix (**main.cf**)

Se realizaron modificaciones en el archivo de configuración principal de Postfix (**/etc/postfix/main.cf**):

- **Configuración de Relay:** Se agregó la dirección de Google (**[smtp.gmail.com]:587**) y se activó la autenticación SASL y el uso de TLS para cifrar la comunicación.

```
GNU nano 8.6 /etc/post
# See /usr/share/postfix/main.cf.dist for a commented, more complete version

# See http://www.postfix.org/COMPATIBILITY_README.html
compatibility_level = 3.11

# Which domain that locally-originated mail appears to come from.
# Debian policy suggests to read this value from /etc/mailname.
#XX needs a review in postinst&config
#myorigin = /etc/mailname
myorigin = $mydomain
#myorigin = /etc/mailname

# Text that follows the 220 code in the SMTP server's greeting banner.
# You MUST specify $myhostname at the start due to an RFC requirement.
smtpd_banner = $myhostname ESMTP $mail_name (Debian)
```

```
# IP protocols to use: ipv4, ipv6, or all
# (set this explicitly so 'post-install upgrade-configuration' wont complain)
inet_protocols = ipv4

# List of "trusted" SMTP clients (maptype:mapname allowed) that have more
# privileges than "strangers". If mynetworks is not specified (the default),
# mynetworks_style is used to compute its value.
#mynetworks_style = class
#mynetworks_style = subnet
mynetworks_style = host
#
mynetworks = 127.0.0.0/8 [::ffff:127.0.0.0]/104 [::1]/128

# Uncomment the next line to generate "delayed mail" warnings
#delay_warning_time = 4h

# List of domains (maptype:mapname allowed) that this machine considers
# itself the final destination for.
mydestination = $myhostname, robertito.com, kali, localhost.localdomain, localhost
```

```

relayhost = [smtp.gmail.com]:587

# Where to look for Cyrus SASL configuration files. Upstream default is unset
# (use compiled-in SASL library default), Debian Policy says it should be
# /etc/postfix/sasl.
cyrus_sasl_config_path = /etc/postfix/sasl

# SMTP server RSA key and certificate in PEM format
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
# SMTP Server security level: none|may|encrypt TrustedSec
smtpd_tls_security_level = may

# List of CAs for SMTP Client to trust
# Prefer this over _CApath when smtp is running chrooted
smtp_tls_CAfile = /etc/ssl/certs/ca-certificates.crt
# SMTP Client TLS security level: none|may|encrypt|...
smtp_tls_security_level = may
# SMTP Client TLS session cache
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
smtpd_relay_restrictions = permit_mynetworks permit_sasl_authenticated defer_unauth_
myhostname = kali
inet_interfaces = all
smtp_use_tls = yes
smtp_sasl_auth_enable = yes
smtp_sasl_security_options = noanonymous
smtp_sasl_password_maps = cdb:/etc/postfix/sasl_passwd

```

### 3. Gestión de Credenciales y Base de Datos (**sasl\_passwd**)

Se creó el archivo `/etc/postfix/sasl_passwd` para almacenar las credenciales del servidor de relay (correo y App Password).

```

GNU nano 8.6
[smtp.gmail.com]:587 villarealailton@gmail.com:

```

**Resolución de Errores (Troubleshooting):** Durante las pruebas iniciales, se detectó un error de autenticación (**AUTH error**) y un aviso indicando que la base de datos `sasl_passwd.db` estaba desactualizada respecto al archivo de texto.

- **Solución:** Se ejecutó el comando `sudo postmap /etc/postfix/sasl_passwd`, lo que permitió mapear correctamente las credenciales y actualizar la base de datos para que Postfix pudiera utilizarlas.

```

(root@kali)-[~]
# postmap /etc/postfix/sasl_passwd

```

## 4. Verificación de Logs

Se monitoreó el servicio mediante `journalctl -u postfix -f`. La evidencia muestra que, tras corregir los errores de mapeo, los correos fueron aceptados por el servidor de Google con el estatus `status=sent (250 2.0.0 OK)`, confirmando que la infraestructura estaba lista para el ataque.

```

root@kali: ~]# journalctl -u postfix -f
Apr 28 00:00:48 kali postfix/smtpd[86080]: connect from localhost[127.0.0.1]
Apr 28 00:00:48 kali postfix/smtpd[86080]: 093DDC0134: client=localhost[127.0.0.1]
Apr 28 00:00:48 kali postfix/cleanup[86083]: 093DDC0134: message-id=<20260428040048.093DDC0134@kali>
Apr 28 00:00:48 kali postfix/smtpd[86080]: disconnect from localhost[127.0.0.1] ehlo=2 starttls=1 mail=1 rcpt=1 data=1 commands=6
Apr 28 00:00:48 kali postfix/qmgr[1461]: 093DDC0134: from=<villarealailton@gmail.com>, size=812, rcpt=1 (queue active)
Apr 28 00:00:48 kali postfix/smtp[86084]: 093DDC0134: to=<josuverosales7450@gmail.com>, relay=smtp.gmail.com[142.250.113.109]:587, delay=2.6, delays=0.02/0.03/0.06/1.9,
tls=may, dsn=2.0.0, status=sent (250 2.0.0 OK 1777348851 586e51a60fabf-433efb816e4sml082228fca.1 - gsmtpt)
Apr 28 00:00:50 kali postfix/qmgr[1461]: 093DDC0134: removed
Apr 28 00:02:22 kali postfix/qmgr[1461]: B6A52C130: from=<villarealailton@gmail.com>, size=816, rcpt=1 (queue active)
Apr 28 00:02:25 kali postfix/smtp[86084]: B6A52C130: to=<josuverosales7450@gmail.com>, relay=smtp.gmail.com[142.250.113.109]:587, delay=1167, delays=1165/0/0.82/1.5, t
ls=may, dsn=2.0.0, status=sent (250 2.0.0 OK 1777348945 586e51a60fabf-433efc2d19sm982311fac.8 - gsmtpt)
Apr 28 00:02:25 kali postfix/qmgr[1461]: B6A52C130: removed

```

## 5. Configuración y Uso de Social-Engineer Toolkit (SET)

Se procedió a ejecutar el Social-Engineer Toolkit (SET), una suite diseñada para la automatización de ataques de ingeniería social. El menú principal permite seleccionar entre diversos vectores de ataque, siendo el de correo electrónico el elegido para esta práctica

[illegible]



## 6. Selección del Vector de Ataque

Dentro del menú de SET, se seleccionó la opción **5) Mass Mailer Attack** para gestionar el envío de correos. Posteriormente, se optó por la modalidad de ataque a una dirección individual (**1. E-Mail Attack Single Email Address**) con el fin de realizar una prueba dirigida y controlada.

```
set> 5

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

set:mailer>1
```

Se eligió la opción **2) One-Time Use Email Template**. Este paso permitió la creación de una plantilla de correo personalizada desde cero, facilitando la inclusión de etiquetas HTML y un lenguaje persuasivo diseñado para el objetivo específico de la simulación.

```
Do you want to use a predefined template or craft
a one time email template.

1. Pre-Defined Template
2. One-Time Use Email Template

set:phishing>2
```

Se configuró el asunto del correo con un tono de urgencia y beneficio. El cuerpo del mensaje, redactado en HTML, suplanta la identidad de la gerencia de un gimnasio local e incluye un enlace directo hacia la página

```
set:phishing> Subject of the email: ¡Activa tus musculos estudiantiles con esta Nueva PROMOCION!
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: h
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished: Estimado Alumno<br>
Next line of the body: Nos complace informarle que el gimnasio Robert4EsGrande, ha lanzado una nueva promocion SOLO PARA USTED<br>
Next line of the body: TOTALMENTE IMPERDIBLE para cuidar su salud, con un 70% de descuento de por VIDA<br>
Next line of the body: ingresa a nuestro portal con tu correo INSTITUCIONAL<br>
Next line of the body: Totalmente importante pues es SOLO para estudiantes activos de la POLITECNICA
Next line of the body: <br><a href="https://roberto182377.github.io/ssu.upslp.edu.mx/Self-Service%20-%20Acceder.html">ENTRA AQUI</a><br>
Next line of the body: END
set:phishing> Send email to: 181760@upslp.edu.mx
```



## 7. Configuración del Servidor SMTP de Salida

En este módulo técnico, se seleccionó la opción **2) Use your own server or open relay**. Se definió la dirección local **127.0.0.1** y el puerto **25** para que SET utilizara el servidor Postfix configurado previamente como puente de salida. Asimismo, se establecieron los parámetros del remitente (**FROM NAME**) para que el usuario visualice el nombre, reforzando la técnica de suplantación.

```
1. Use a gmail Account for your email attack.
2. Use your own server or open relay

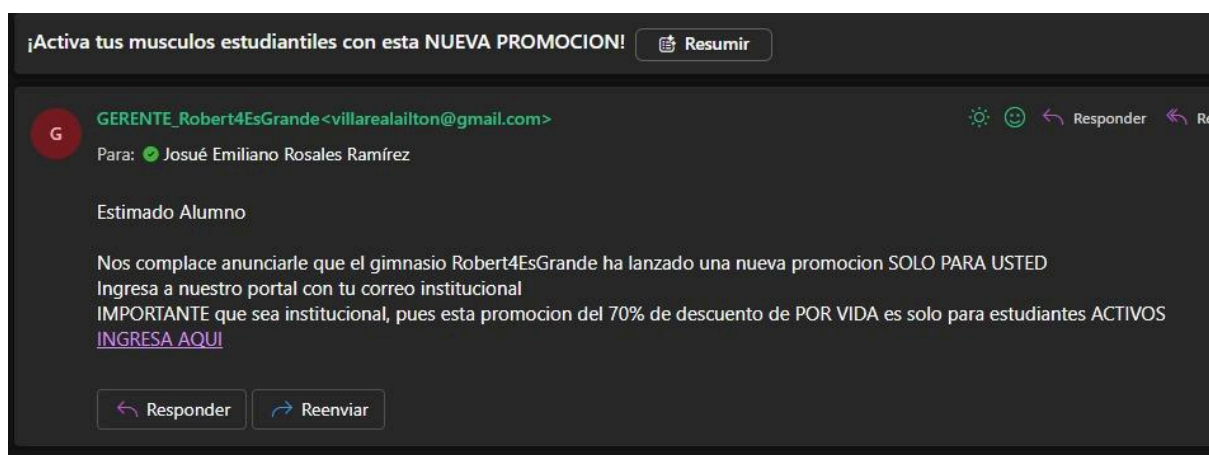
set:phishing>2
set:phishing> From address (ex: moo@example.com): villarealailton@gmail.com
set:phishing> The FROM NAME the user will see: GERENTE_Robert4EsGrande
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): 127.0.0.1
set:phishing> Port number for the SMTP server [25]: 25
set:phishing> Flag this message/s as high priority? [yes|no]:
```

Una vez completada la configuración de los parámetros de red y el diseño del mensaje, la herramienta procedió a la inyección del correo en el servidor de retransmisión. El sistema notificó el envío exitoso, marcando el inicio de la fase de interacción con el usuario final.

```
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
[*] SET has finished sending the emails

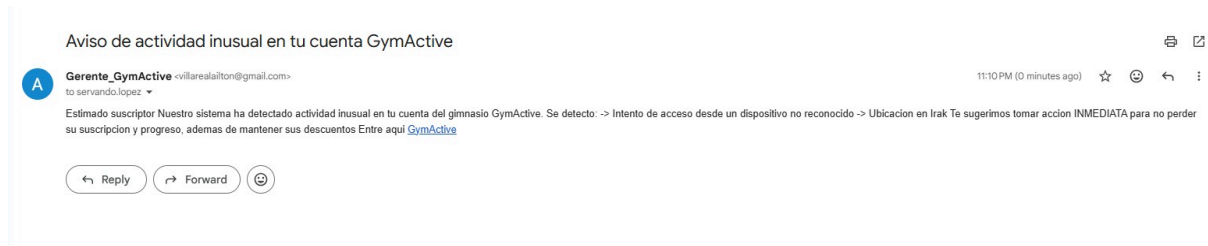
Press <return> to continue
```

Teniendo como resultado:

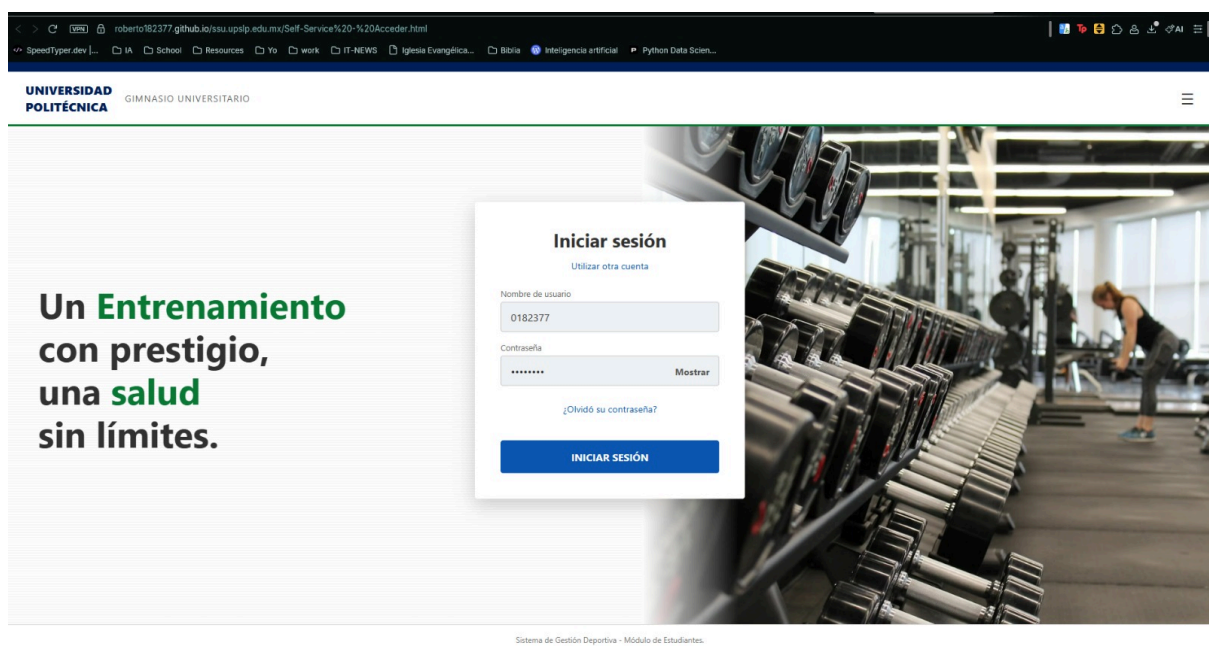


# Resultados

Con la metodología aplicada, generamos un nuevo correo esto enviándolo a la dirección:  
[servando.lopez@upslp.edu.mx](mailto:servando.lopez@upslp.edu.mx)



Al hacer clic en el enlace, el usuario será dirigido a una página de inicio de sesión del sitio de gym falsificada.



## Análisis de riesgos

El éxito de la infiltración permite identificar los siguientes riesgos críticos según la tríada de la seguridad (CIA):

- **Vulnerabilidades Técnicas Explotadas:**
  - **Falta de Registros Anti-Spoofing:** La ausencia de registros SPF (Sender Policy Framework), DKIM y DMARC en el dominio emisor permitió que el servidor Postfix suplantara identidades sin ser bloqueado por el protocolo de verificación de origen.
  - **Debilidad en el Gateway de Correo:** Los filtros de contenido no detectaron patrones de "Credential Harvesting" en el cuerpo del HTML enviado.

- **Impacto en el Negocio:**
  - **Confidencialidad (Alta):** Compromiso total de cuentas institucionales, permitiendo el acceso a información privada y bases de datos protegidas.
  - **Integridad (Media):** Posibilidad de realizar ataques de "Man-in-the-Middle" o cambiar registros financieros tras el acceso inicial.
- **Probabilidad de Ocurrencia:** Alta. La disponibilidad de herramientas automatizadas (SET) y servicios de relay gratuitos reduce la barrera técnica para atacantes externos.

## Recomendaciones de mitigación

| Recomendación                    | Medida a implementar                                                                                                                                                                                                                                                                                                                                                                     |
|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Controles Técnicos</b>        | <b>Implementación de SPF/DKIM:</b> Configurar registros DNS para validar que los correos solo provengan de servidores autorizados.<br><b>Filtros Anti-Spam:</b> Activar motores de inspección de reputación en el gateway de correo.<br><b>MFA (Autenticación de Múltiples Factores):</b> Desplegar 2FA para que la captura de contraseñas por sí sola no sea suficiente para el acceso. |
| <b>Controles Administrativos</b> | <b>Programa de Concientización:</b> Realizar simulacros periódicos para que los usuarios identifiquen correos sospechosos y el uso de enlaces externos.                                                                                                                                                                                                                                  |

## Bibliografía

- Arsys. (s. f.). *El servidor de correo Postfix: características y mejores prácticas*.  
<https://www.arsys.es/blog/postfix-caracteristicas-mejores-practicas>
- Cyber Talents (s.f.). What is Social Engineering Toolkit? [Complete Guide].  
<https://cybertalents.com/blog/what-is-social-engineering-toolkit-complete-guide>
- Postfix (s.f.). Postfix Documentation.<https://www.postfix.org/documentation.html>
- RHT Services Home Improvement. (2018, 13 marzo). *Use Postfix with Gmail as SMTP Server on Ubuntu Linux* [Vídeo]. YouTube.  
<https://www.youtube.com/watch?v=yHUigLSmGOE>